

Annex E: DevSecOps Reference Pointers

Challenge 2: The Quantum Routing Brain

DoD software development standards, container security toolchains, edge Kubernetes, and CI/CD patterns relevant to the Engineering Quality criterion. Everything listed here is free and open-source or publicly available documentation.

Scope. This annex is a stretch-goal reference. Your minimum viable demo needs Docker Compose and a clean repo. Everything below is for teams that want to score higher on Engineering Quality and Defense Realism by aligning their build practices with how DoD actually ships software.

DOD DEVSECOPS REFERENCE DESIGN

The DoD Chief Information Officer publishes a set of reference documents that define how software should be built, tested, and deployed across the department. These are the authoritative standards that defense software programs are evaluated against.

DevSecOps Fundamentals — Overview of the DoD DevSecOps lifecycle, principles, and organizational expectations. Start here for context. Available at <https://dodcio.defense.gov/Library/>.

DevSecOps Reference Design v1.0 — The core architecture document. Defines the 8-phase lifecycle: plan, develop, build, test, release, deliver, deploy, operate/monitor. Your demo should map to at least the build-test-deploy phases. Same URL.

CNCF Kubernetes Reference Design — DoD-specific guidance for running Kubernetes in defense environments. Covers multi-cluster patterns, network policies, and security baselines. Cleared 2021-10-22. Same URL.

DevSecOps Activities & Tools Guidebook v2.x — Detailed tool recommendations for each lifecycle phase. Lists approved scanners, CI/CD engines, artifact registries, and observability stacks. Same URL.

cATO (Continuous Authorization to Operate) — DoD CIO memo (3 February 2022) enabling continuous rather than point-in-time security authorization. Requires three pillars: Continuous Monitoring, Active Cyber Defense, and Secure Software Supply Chain. The third pillar explicitly requires adoption of an approved DevSecOps reference design. Evaluation criteria at <https://dodcio.defense.gov/Portals/0/Documents/Library/cATO-EvaluationCriteria.pdf>. If your demo maps components to the three cATO pillars, that scores highly on Defense Realism.

PLATFORM ONE / BIG BANG / IRON BANK

Platform One is the DoD's enterprise DevSecOps platform, run by AFLCMC/HBB Detachment 12 at Hanscom AFB. It serves approximately 36,000 daily users across 156 customer application teams. You are not deploying on Platform One. But aligning your toolchain with their stack demonstrates that your architecture is defense-compatible.

Big Bang — An umbrella Helm chart that GitOps-deploys an approved package set into any conformant Kubernetes cluster. The entire source is public on GitHub: <https://github.com/DoD-Platform-One/bigbang>. You can browse, clone, and study this freely. The current (2025–2026) default stack includes:

Function	Big Bang Default	Your Demo Equivalent
Service mesh	Istio	Not needed for Docker Compose. If using K3s, Istio is optional.
GitOps engine	FluxCD	GitHub Actions or any CI runner.
Policy enforcement	Kyverno	Kyverno is lightweight and runs on K3s. Use <code>verifyImages</code> policy to enforce container signatures.
Runtime security	NeuVector	Not needed for demo.
Logging	Promtail/Alloy → Loki → Grafana	Grafana + Loki via Docker Compose is achievable in a day. Even plain <code>docker logs</code> with structured JSON is acceptable.
SSO	Keycloak	Not needed for demo.
Image scanning	Anchore Enterprise	Use Trivy or Gype (free, CLI).

Iron Bank — The DoD's hardened container image repository. Over 1,800 scanned, signed, and compliance-documented images. Public source mirrors at <https://repo1.dso.mil/dsop> (free account). The `hardening_manifest.sche` is a useful template for your own container manifest. If you base your containers on Iron Bank images (e.g., `ironbank/opensource/python/python310`), that demonstrates supply-chain awareness.

CONTAINER SECURITY TOOLCHAIN (FREE, ACHIEVABLE IN DAYS)

The following toolchain implements the Secure Software Supply Chain pillar of cATO. Each tool is free, open-source, and installable in minutes. Together they give your demo a defensible software supply chain story.

Vulnerability Scanning

Trivy — Aqua Security's vulnerability scanner. Scans container images, filesystems, git repos, and IaC. `trivy image your-image:latest` produces a CVE report in seconds. <https://github.com/aquasecurity/trivy>.

Gype — Anchore's vulnerability scanner. Alternative to Trivy. `gype your-image:latest`. <https://github.com/anchore/gype>.

Pick one. Run it in your CI pipeline on every container build.

SBOM Generation

Syft — Anchore's Software Bill of Materials generator. Produces SPDX or CycloneDX SBOMs from container images. `syft your-image:latest -o spdx-json > sbom.json`. <https://github.com/anchore/syft>. Executive Order 14028 (May 2021) requires SBOMs for all software sold to the federal government. Generating one shows you know this requirement exists.

Container Signing

Cosign (Sigstore) — Keyless container signing via OIDC (sign with your GitHub identity, no key management). `cosign sign -yes your-image:latest`. Signatures are recorded in the Rekor transparency log. <https://github.com/sigstore/cosign>.

Fulcio — Sigstore's short-lived certificate authority. Issues certificates bound to your OIDC identity (GitHub, Google, Microsoft). Cosign uses Fulcio automatically in keyless mode.

Rekor — Sigstore's immutable transparency log. Every signature is recorded publicly. Auditable proof that a specific identity signed a specific image at a specific time.

Admission Enforcement

Kyverno `verifyImages` — Kubernetes admission policy that rejects any container image without a valid Cosign signature. Runs as a webhook. YAML-only policies (no Rego). <https://kyverno.io/docs/writing-policies/verify-images/>. If you deploy on K3s, add a Kyverno policy that enforces signed images. That is a one-file addition with high scoring impact.

Provenance

SLSA (Supply-chain Levels for Software Artifacts) — Google-originated framework for supply chain integrity. Levels 1–4. `slsa-github-generator` produces SLSA L2/L3 provenance attestations in GitHub Actions. <https://slsa.dev/> and <https://github.com/slsa-framework/slsa-github-generator>. Adding SLSA provenance to your build pipeline is a 10-line GitHub Actions addition.

Putting It Together

Minimal CI/CD pipeline (achievable in 2–3 hours):

1. GitHub Actions workflow triggers on push to `main`.
2. Build container image.
3. `syft` generates SBOM → attach as build artifact.
4. `trivy` scans for CVEs → fail build on CRITICAL/HIGH.
5. `cosign sign -yes` signs the image keylessly.
6. `slsa-github-generator` produces provenance attestation.
7. Push signed image to GitHub Container Registry (GHCR).
8. (If on K3s) Kyverno `verifyImages` policy rejects unsigned images at admission.

EDGE KUBERNETES

If your team goes beyond Docker Compose and deploys on Kubernetes, use an edge-optimized distribution.

K3s — Rancher's lightweight Kubernetes distribution. Single binary, under 70 MB, CNCF Sandbox since June 2020. Runs on ARM64 (Raspberry Pi) and x86. The de facto choice for DoD edge demos. <https://k3s.io/>. Install: `curl -sfL https://get.k3s.io | sh -`.

KubeEdge — CNCF Graduated project (September 2024) for extending Kubernetes to edge nodes. More complex than K3s but designed for cloud-edge coordination where the edge node has intermittent connectivity to the control plane. <https://kubedge.io/>.

Liqo — Politecnico di Torino project. Uses Virtual Kubelet to map a remote cluster as a local node. A pod scheduled to the virtual node actually runs on the remote cluster. Cleanest UX for demoing "edge offloads to cloud QPU": your router schedules a pod labeled `tier=quantum` to the Liqo virtual node, and it transparently runs on the cloud cluster where the quantum backend lives. <https://liqo.io/>.

Recommendation for Dry Dock. Start with Docker Compose. Get the router, classical backend, and quantum backend working as three containers on your laptop. If you have time on day 4–5, migrate to K3s on two machines (or two VMs) and show multi-cluster routing. K3s adds tactical credibility. Docker Compose is perfectly acceptable.

KEY REFERENCE DOCUMENTS (ALL PUBLIC)

Document	URL
DoD DevSecOps Reference Design	https://dodcio.defense.gov/Library/
cATO Evaluation Criteria	https://dodcio.defense.gov/Portals/0/Documents/Library/cATO-EvaluationCriteria.pdf
cATO Memo (3 Feb 2022)	https://media.defense.gov/2022/Feb/03/2002932852/-1/-1/0/CONTINUOUS-AUTHORIZATION-TO-OPERATE.PDF
DoD Zero Trust Strategy (21 Oct 2022)	https://dodcio.defense.gov/Portals/0/Documents/Library/
MOSA Implementation Guidebook (Feb 2025)	https://cto.mil/wp-content/uploads/2025/03/MOSA-Implementation-Guidebook-27Feb2025-Cleared.pdf
Platform One Big Bang (GitHub)	https://github.com/DoD-Platform-One/bigbang
Iron Bank (Repo1)	https://repo1.dso.mil/dsop
K3s	https://k3s.io/
Kyverno	https://kyverno.io/
Sigstore (Cosign, Fulcio, Rekor)	https://www.sigstore.dev/
SLSA	https://slsa.dev/
Syft	https://github.com/anchore/syft
Trivy	https://github.com/aquasecurity/trivy
SPIFFE/SPIRE	https://spiffe.io/
Liqo	https://liqo.io/